

GoldFin Desk — Plaid Integration Operations & Maturity Policy

Version: 2026-06-26.1 **Owner:** Chris Sam, Founder **Engineering lead:** GoldFin Desk Engineering
Review cadence: Quarterly (next review due no later than 90 days from version date) **Status:** Active, automatically enforced where applicable

1. Purpose

This document defines how GoldFin Desk integrates with Plaid, how it protects end-user financial data obtained through Plaid, and how the program is continuously matured. It exists to satisfy:

- Plaid's End User Services Agreement (EUSA) and End User Data Processing Addendum (EUDPA)

- The storage-limitation, integrity, and confidentiality principles of GDPR

Art. 5

- CCPA / CPRA security and deletion obligations (Cal. Civ. Code §1798.100 et seq.)
- Canada's PIPEDA (Principles 4.5 and 4.7)
- SOC 2 Trust Services Criteria (CC6, CC7, CC8)

2. Scope

All GoldFin Desk systems, environments, employees, contractors, and sub-processors that touch:

- Plaid Link sessions (browser SDK)
- Plaid Items, Accounts, Auth, Balance, Transactions, Identity
- Plaid webhooks (TRANSACTIONS, ITEM, AUTH, HOLDINGS, etc.)
- Any database row derived from a Plaid response

Out of scope: marketing analytics, public website telemetry.

3. Roles and responsibilities

Role	Responsibility
Founder (Chris Sam)	Policy owner. Approves changes. Signs quarterly review.
Engineering lead	Implements controls. Maintains this document. Triage incidents.
On-call engineer	First responder to Plaid webhook failures and item-error alerts.
Support	User-facing communication during incidents and data subject requests.

4. System description (data flow)

```

Browser (Plaid Link SDK)
  ■
  ■ 1. POST /functions/v1/plaid-create-link-token (JWT auth)
  ▼
Edge: plaid-create-link-token ■■ Plaid /link/token/create
  ■
  ■ 2. user completes bank login in Plaid Link
  ▼
Browser receives public_token
  ■
  ■ 3. POST /functions/v1/plaid-exchange-public-token (JWT auth)
  ▼
Edge: plaid-exchange-public-token
  ■ ■■■ Plaid /item/public_token/exchange ■■■ access_token
  ■ ■■■ Plaid /accounts/get
  ■ ■■■ DB: plaid_items, plaid_accounts (RLS: owner only)
  ▼
Async: Plaid webhooks ■■■ /functions/v1/plaid-webhook
      (HMAC-SHA256 signature verified)
      ■■■ webhook_events, transaction sync

```

5. Environments and secret management

Environment	API host	Secret name	Storage
Sandbox	sandbox.plaid.com	PLAID_SANDBOX_SECRET	Lovable Cloud secret store
Production	production.plaid.com	PLAID_PRODUCTION_SECRET	Lovable Cloud secret store

Environment	API host	Secret name	Storage
Shared	—	PLAID_CLIENT_ID, PLAID_WEBHOOK_SECRET	Lovable Cloud secret store

- Environment is selected at runtime by `PLAID_ENV` (sandbox | production).
- Secrets are never committed to source control, never logged, never returned in HTTP responses, and never accessible from the browser.
- Rotation cadence: every 180 days, or immediately upon suspected compromise, staff departure, or a Plaid security advisory.
- Rotation procedure: generate new secret in Plaid Dashboard → store via Lovable Cloud secret tool → redeploy edge functions → revoke old secret in Plaid Dashboard within 24 hours.

6. Access control

- All Plaid-derived tables (`plaid_items`, `plaid_accounts`, `plaid_transactions`) have Row-Level Security enabled.
- Policies restrict `SELECT/INSERT/UPDATE/DELETE` to `auth.uid() = user_id`.
- The service-role key is used only inside edge functions, never client-side.
- Administrative read access is limited to users in the `admin` role (see `public.has_role`), audited via the admin audit dashboard.
- Engineering production database access is read-only by default and logged.

7. Token lifecycle

Stage	Storage	Lifetime	Disposal
Link token	Browser memory only	≤ 30 min	Discarded with page
Public token	Browser memory only	≤ 30 min	Exchanged immediately
Access token	<code>plaid_items.access_token</code> (encrypted at rest by Postgres)	Until user disconnects or account deleted	<code>/item/remove</code> + row delete

Stage	Storage	Lifetime	Disposal
Webhook payloads	webhook_events table	90 days	Daily retention sweep

User-initiated disconnect (/portal/settings) and account deletion both call Plaid /item/remove **before** purging the row, so Plaid stops sending data about that item.

8. Webhook handling

- All Plaid webhooks hit POST /functions/v1/plaid-webhook.
- The request body is HMAC-SHA256 verified against PLAID_WEBHOOK_SECRET.

Requests with an invalid or missing signature are rejected with HTTP 401 and logged.

- Every webhook is persisted to webhook_events with source='plaid', event_type, payload, and received_at.
- Transaction sync uses Plaid's /transactions/sync cursor pattern (no polling).
- Failures are retried by Plaid; persistent failures surface in the admin audit dashboard's "last webhook" column.

9. Incident response runbook

- **Detect.** Pager triggers on (a) >5% webhook 5xx rate over 10 min, (b) failed /link/token/create rate >5%, or (c) any ITEM_ERROR storm.
- **Triage.** On-call engineer opens the admin audit dashboard, inspects webhook_events and cron_runs for the affected window.
- **Contain.** If credential compromise is suspected:
 - a. Rotate PLAID_PRODUCTION_SECRET and PLAID_WEBHOOK_SECRET immediately.
 - b. Mark affected plaid_items.status = 'reauth_required'.
 - c. Call Plaid /item/remove on any items whose access tokens may be exposed.
- **Communicate.** Notify affected users within 72 hours of confirmed unauthorized access (GDPR Art. 33/34 timeline).
- **Report.** File a Plaid security report at security@plaid.com within 72 hours.
- **Post-mortem.** Written within 5 business days, attached to this policy as

an appendix entry, with at least one durable control change.

10. Change management

- Any pull request that modifies code under `supabase/functions/plaid-*`, `src/components/portal/plaid/`, or any table whose name begins with `plaid_` **must** update this document in the same PR.
- The version string at the top of this document follows `YYYY-MM-DD.N` and must be bumped on every change.
- Bumping the version triggers an admin banner prompting re-acknowledgement at next sign-in.

11. Sub-processors and vendor management

Sub-processor	Purpose	Region	Agreement
Plaid Inc.	Bank data aggregation	US	EUSA + EUDPA
Stripe Inc.	Billing	US	DPA
Resend	Transactional email (OTP, reports)	US	DPA
Lovable Cloud (Supabase)	Database, auth, edge functions, secrets	US	DPA

The list is reviewed at every quarterly policy review. New sub-processors require founder sign-off before production rollout.

12. Retention alignment

Plaid-derived data follows the published GoldFin Desk [Data Retention & Deletion Policy](#). Highlights:

- Disconnected items: purged 30 days after disconnect, after `/item/remove`.
- Advisory reports derived from Plaid data: 24 months.
- Webhook event log: 90 days.
- User deletion request: full purge after a 30-day grace window.

13. Maturity model

GoldFin Desk uses a 5-level maturity model adapted from CMMI/NIST PRISMA.

Level	Name	Definition
1	Initial	Ad hoc; controls undocumented.
2	Repeatable	Controls documented; performed by specific people.
3	Defined	Controls codified, automated where possible, reviewed quarterly.
4	Managed	Metrics collected; control effectiveness measured.
5	Optimizing	Continuous improvement loop with measured outcomes.

Current self-assessed level: 3 (Defined). Target by next annual review: 4 (Managed).

Specific level-4 gaps being closed:

- Add automated monthly drift check comparing live RLS policies vs. declared policy.
- Add SLO dashboards for webhook latency and link-token success rate.
- Add quarterly tabletop exercise against the §9 runbook.

14. Review cadence (how this policy stays "constantly matured")

- **Quarterly review:** founder + engineering lead read the policy end to end, validate each control is still in place, and log the review in the admin audit dashboard. Any drift becomes an action item with a named owner.
- **Triggered review:** the policy is also re-reviewed after any §9 incident, any new sub-processor, any change to Plaid's EUSA/EUDPA, and any material product change touching Plaid data.
- **Annual external review:** the policy is reviewed against the then-current

Plaid product surface and any new regulatory guidance once per year.

- **Version log:** every review appends a row to §15 even if no change was required (an explicit "reviewed, no change" entry).

15. Change log

Version	Date	Author	Summary
2026-06-26.1	2026-06-26	Chris Sam	Initial published version. Maturity level 3.

Questions or reports of suspected security issues: security@goldfindesk.com.